

Индивидуальный проект
Тестирование веб-приложений на примере Damn Vulnerable
Web Application (DVWA)
Этап 4 - Использование Nikto

Дисциплина: Информационная безопасность

Студент: Оганнисян Гор Акаикович

Группа: НБИбд-01-24

Дата выполнения: 01.05.2026

1. Цель работы

Изучить назначение и базовые возможности утилиты Nikto в условиях учебной лаборатории, а также получить практические навыки базовой проверки безопасности веб-сервера и веб-приложения DVWA на наличие типовых проблем конфигурации.

2. Введение

Nikto - это консольный сканер безопасности веб-серверов. Он выполняет автоматизированную проверку HTTP/HTTPS-сервиса и помогает обнаруживать распространённые проблемы: небезопасные файлы, стандартные директории, устаревшие версии серверного программного обеспечения, лишние заголовки и ошибки настройки.

В рамках дисциплины по информационной безопасности Nikto рассматривается только как учебный инструмент аудита. Его применение допустимо на собственном стенде, локальной виртуальной машине, DVWA или другой системе, где у студента есть прямое разрешение на тестирование.

Главная цель работы заключается не во взломе сервера, а в понимании того, какие признаки неправильной настройки может увидеть специалист по безопасности и какие меры защиты необходимо предложить после анализа результата.

3. Требования и предварительная подготовка

Для выполнения этапа рекомендуется подготовить:

- Kali Linux или другой дистрибутив Linux с установленной утилитой Nikto;
- локальный учебный веб-сервер с DVWA или аналогичным тестовым приложением;
- известный адрес тестовой машины, например <http://192.168.56.101/DVWA/>;
- доступность веб-сервера по HTTP или HTTPS;
- разрешение на проведение проверки, если стенд не принадлежит студенту;
- папку для сохранения результата сканирования.

Перед запуском сканирования необходимо убедиться, что тест выполняется в изолированной лабораторной среде. Проверка чужих сайтов, публичных IP-адресов и реальных производственных систем без разрешения недопустима.

4. Назначение Nikto и общий принцип работы

Nikto отправляет к веб-серверу набор HTTP-запросов и анализирует полученные ответы. На основе базы известных проверок инструмент пытается определить, присутствуют ли на сервере типовые ошибки конфигурации или потенциально опасные файлы.

При работе Nikto может проверять:

- информационные HTTP-заголовки сервера;
- доступность стандартных директорий и файлов;
- наличие тестовых, резервных или служебных файлов;
- использование устаревших версий веб-сервера или компонентов;
- опасные HTTP-методы и слабые настройки;
- отсутствие некоторых защитных заголовков.

Результаты Nikto не всегда являются подтверждёнными уязвимостями. Часть сообщений требует ручной проверки, потому что сканер может выявить только признак проблемы, а окончательное заключение должен сделать специалист.

5. Пошаговое использование в учебной среде

Ниже приведён безопасный пример для локального учебного стенда DVWA, размещённого в виртуальной сети. В качестве адреса тестовой машины используется 192.168.56.101, веб-сервер работает на порту 80, а приложение доступно по пути /DVWA/.

Пример исходных условий учебного стенда:

- адрес тестовой машины: 192.168.56.101;
- протокол: HTTP;
- порт: 80;
- путь к учебному приложению: /DVWA/;
- цель проверки: выявление типовых проблем конфигурации веб-сервера.

Проверка доступности Nikto:

```
nikto -Version
```

Базовый запуск сканирования локального учебного стенда:

```
nikto -h http://192.168.56.101/DVWA/
```

Запуск с указанием порта и сохранением результата в текстовый файл:

```
nikto -h http://192.168.56.101/DVWA/ -p 80 -o ./nikto_result.txt -Format txt
```

Запуск с сохранением результата в HTML-файл для удобного просмотра:

```
nikto -h http://192.168.56.101/DVWA/ -p 80 -o ./nikto_result.html -Format htm
```

Пояснение параметров

- -h http://192.168.56.101/DVWA/ - адрес проверяемого учебного веб-приложения;
- -p 80 - номер порта веб-сервера;
- -o ./nikto_result.txt - путь к файлу, куда сохраняется результат;
- -Format txt - формат отчёта в виде обычного текстового файла;
- -Format htm - формат отчёта в виде HTML-страницы;
- nikto -Version - проверка установленной версии Nikto.

6. Пример анализа результата

После завершения сканирования необходимо открыть файл nikto_result.txt или nikto_result.html и изучить найденные сообщения. В отчёте Nikto обычно указывает адрес цели, порт, сведения о сервере и список обнаруженных замечаний.

Пример возможных сообщений в учебной среде:

- сервер раскрывает информацию о версии программного обеспечения;
- не настроены некоторые защитные HTTP-заголовки;
- обнаружены стандартные директории или страницы по умолчанию;

- найдены файлы, которые могут раскрывать лишнюю информацию;
- включены методы или настройки, которые требуют дополнительной проверки.

При анализе результата важно не считать каждую строку отчёта готовой уязвимостью. Например, отсутствие заголовка безопасности может быть замечанием к конфигурации, а найденная директория может оказаться недоступной для реального использования. Поэтому вывод должен основываться на проверке контекста и назначении учебного стенда.

Если Nikto обнаружил большое количество предупреждений, это означает, что веб-сервер требует дополнительной настройки. В реальной инфраструктуре такие проблемы могут повысить риск раскрытия информации, упростить разведку для злоумышленника или показать, что сервер давно не обновлялся.

7. Практические рекомендации по защите

По итогам проверки рекомендуется:

- обновлять веб-сервер, PHP, CMS и другие компоненты до актуальных версий;
- удалять стандартные страницы, тестовые файлы, резервные копии и лишние директории;
- скрывать или ограничивать раскрытие информации о версиях ПО в HTTP-заголовках;
- настраивать защитные заголовки, например X-Frame-Options и X-Content-Type-Options;
- запрещать опасные HTTP-методы, если они не используются приложением;
- ограничивать доступ к административным разделам;
- вести журналирование запросов и отслеживать подозрительную активность;
- периодически проводить повторную проверку после изменения конфигурации.

8. Частые ошибки при использовании Nikto

- сканирование выполняется не в лабораторной среде и без разрешения владельца ресурса;
- неверно указан URL или путь к приложению;
- перепутаны протоколы HTTP и HTTPS;
- не указан нужный порт веб-сервера;
- результат сканера воспринимается как окончательное доказательство уязвимости без ручной проверки;
- не сохраняется отчёт, из-за чего сложно подтвердить результаты работы;
- сканирование запускается слишком часто и создаёт лишнюю нагрузку на учебный стенд.

9. Безопасность и правовые аспекты

Nikto является инструментом двойного назначения. Он полезен для обучения и аудита безопасности, но его нельзя применять против чужих сайтов и серверов без письменного разрешения владельца.

В рамках данного проекта все действия должны выполняться только на DVWA, локальной виртуальной машине или другом специально подготовленном учебном стенде. Нельзя использовать результаты сканирования для дальнейшего несанкционированного доступа, изменения файлов, обхода защиты или нарушения работы сервера.

Правильное использование Nikto предполагает ответственное отношение: сначала получить разрешение, затем выполнить проверку, зафиксировать результат и предложить меры защиты.

10. Заключение

В ходе выполнения этапа студент знакомится с назначением Nikto и получает представление о том, как проводится базовая проверка безопасности веб-сервера. На примере учебного стенда DVWA рассматривается запуск сканирования, сохранение результата и первичный анализ найденных замечаний.

Практическая ценность работы состоит в том, что студент учится видеть типовые ошибки настройки веб-сервера и формулировать рекомендации по их устранению. Nikto не заменяет полноценный аудит безопасности, но является полезным инструментом для первичного выявления проблем.

11. Источники и литература

1. Nikto - официальная документация и репозиторий проекта.
2. Документация Kali Linux.
3. DVWA - учебное веб-приложение для практики по информационной безопасности.
4. Материалы по безопасной настройке веб-серверов Apache и Nginx.
5. Материалы по защитным HTTP-заголовкам и базовому аудиту веб-приложений.